Vulnerability Assessment Report

1. Executive Summary

A read-only vulnerability assessment was performed against the publicly accessible GitLab web environment, beginning with `https://gitlab.com/`. During assessment, the target redirected to `https://about.gitlab.com/`, which was subsequently reviewed as part of the observed web flow.

The assessment focused on passive security analysis and configuration review using Nmap, OWASP ZAP passive scanning, and browser-based inspection. No exploitation, brute-force testing, denial-of-service activity, authentication bypass, or other intrusive testing was performed.

Two security configuration weaknesses were identified during the assessment:

1. **CSP: Failure to Define Directive with No Fallback** — Medium risk, identified by OWASP ZAP's passive scanner.
2. **Missing Anti-clickjacking Header** — Medium risk, identified by OWASP ZAP's passive scanner.

The findings are configuration-level observations from a read-only assessment and should not be interpreted as confirmation of an exploitable vulnerability without further authorized testing.

2. Assessment Scope

Target

- Primary target: `https://gitlab.com/`
- Observed redirect target: `https://about.gitlab.com/`

In Scope

- Publicly accessible web pages and HTTP response headers
- Passive security analysis
- Network and service identification

- Security header and Content Security Policy review
- Non-intrusive browser-based inspection

Out of Scope

The following activities were not performed:

- Authentication bypass
- Brute-force attacks
- Exploitation of vulnerabilities
- Denial-of-service testing
- Destructive or intrusive testing
- Access to restricted/private resources
- Testing of third-party services identified during page loading

The assessment was conducted as a read-only security review in accordance with the task requirements.

3. Methodology

The assessment followed a non-intrusive, read-only methodology:

1. **Target identification and reconnaissance**
    - Identified the target domain and observed its HTTP behavior.
    - Performed basic network and service discovery using Nmap.
2. **Passive web security assessment**
    - Used OWASP ZAP in passive scanning mode while browsing the target.
    - Reviewed security-related alerts generated from observed HTTP responses.
3. **Manual verification**
    - Reviewed HTTP response headers using browser Developer Tools.
    - Compared passive scanner observations with the headers returned by the target.
4. **Evidence collection**
    - Captured relevant screenshots and Nmap outputs.
    - Excluded third-party resources and findings that were not directly attributable to the assessed target.

No active vulnerability exploitation or intrusive testing was performed.

4. Tools Used

Tool	Purpose
Nmap	Network and service discovery
OWASP ZAP 2.17.0	Passive web security analysis
Chrome Developer Tools	Manual HTTP response-header verification
GitHub	Evidence and assessment documentation

All testing was performed using non-intrusive techniques appropriate for a read-only assessment.

5. Target Information

Item	Details
Primary Target	`https://gitlab.com/`
Observed Redirect	`https://about.gitlab.com/`
Protocol	HTTPS
Assessment Type	Read-only / passive
Primary Web Technology Observed	Cloudflare
Network Discovery	Nmap
Web Assessment	OWASP ZAP Passive Scanner

Redirect Observation

During the assessment, a request to `https://gitlab.com/` returned an HTTP 301 redirect to:

`https://about.gitlab.com/`

The subsequent security-header observations for the web page were therefore associated with `about.gitlab.com`. This distinction is maintained throughout the report to avoid attributing observations from the redirect destination directly to the original `gitlab.com` endpoint.

6. Network & Service Discovery

Nmap was used to perform basic network and service discovery against `gitlab.com`.

Nmap Service Detection

The following TCP ports were identified as open:

Port	State	Service	Detection
80/tcp	Open	HTTP	Cloudflare HTTP proxy
443/tcp	Open	HTTPS	Cloudflare HTTP proxy

The observed services indicate that HTTP and HTTPS traffic is handled through Cloudflare's proxy infrastructure.

HTTP Header and Title Enumeration

Nmap HTTP scripts were also used to inspect the HTTP/HTTPS endpoints and retrieve available HTTP response information.

The Nmap results were used for service identification and configuration observation only. No exploitation or intrusive testing was performed.

Evidence:
See `Evidence/Nmap/` for the Nmap service-detection and HTTP enumeration outputs.

7. Security Findings

Finding 1 — CSP: Failure to Define Directive with No Fallback

Risk: Medium
Confidence: High
Source: OWASP ZAP Passive Scanner
Affected URL: `https://gitlab.com/`
Observed redirect: `https://about.gitlab.com/`
Parameter: `Content-Security-Policy`

Description

OWASP ZAP's passive scanner identified a Content Security Policy configuration issue involving directives that do not fall back to `default-src`.

The observed CSP did not explicitly define all directives that require their own policy. In particular, the `form-action` directive was identified as missing from the policy. For directives without a fallback mechanism, omission may result in less restrictive browser behavior.

This finding represents a configuration-level observation from passive analysis. No exploitation was performed to determine whether the configuration results in a practical security impact.

Potential Impact

An incomplete Content Security Policy can reduce the protection provided by CSP against certain classes of web attacks. Depending on the application's functionality and other security controls, insufficiently restrictive CSP directives may increase exposure to unintended resource or form submission behavior.

Evidence

OWASP ZAP reported:

- Alert: `CSP: Failure to Define Directive with No Fallback`
- Risk: Medium
- Confidence: High
- Parameter: `content-security-policy`
- Source: Passive Scanner
- Directive identified: `form-action`

See:

- `Evidence/ZAP/zap-csp-evidence.png`
- `Evidence/ZAP/zap-csp-overview.png`

Recommendation

Review and explicitly define CSP directives that do not fall back to `default-src`, including `form-action`, according to the application's intended security policy.

The CSP should be tested after modification to ensure that legitimate application functionality continues to operate correctly.

Finding 2 — Missing Anti-clickjacking Header

Risk: Medium
Confidence: Medium
Source: OWASP ZAP Passive Scanner
Affected URL: `https://about.gitlab.com/`
Parameter: `X-Frame-Options`

Description

OWASP ZAP's passive scanner identified that the observed response did not provide an `X-Frame-Options` header and did not identify an equivalent `frame-ancestors` protection sufficient to prevent clickjacking.

The response should use an appropriate anti-framing policy to control whether the page can be embedded within frames on other origins.

This finding is based on passive response-header analysis only. No clickjacking exploitation or framing attack was performed.

Potential Impact

If a sensitive page can be embedded by an unauthorized origin, an attacker could potentially attempt to trick users into interacting with the embedded page while believing they are interacting with another interface.

The practical impact depends on the page's functionality, authentication state, and other browser security controls.

Evidence

OWASP ZAP reported:

- Alert: `Missing Anti-clickjacking Header`
- Risk: Medium
- Confidence: Medium
- Parameter: `x-frame-options`
- Source: Passive Scanner
- CWE: 1021

See:

- `Evidence/ZAP/zap-anti-clickjacking-details.png`
- `Evidence/ZAP/zap-anti-clickjacking.png`

Recommendation

Configure an appropriate anti-clickjacking policy.

For example, where applicable:

- `X-Frame-Options: DENY`

or:

- `X-Frame-Options: SAMEORIGIN`

Alternatively, use the Content Security Policy `frame-ancestors` directive to explicitly define permitted framing origins.

The selected policy should be tested against legitimate application requirements before deployment.

8. Security Header Verification

Manual verification of HTTP response headers was performed using Chrome Developer Tools after following the observed redirect to `https://about.gitlab.com/`.

The following security-related headers were observed:

Security Header	Observation	Status
Strict-Transport-Security	`max-age=31536000`	Present
Content-Security-Policy	CSP policy observed	Present
X-Frame-Options	Not observed in the reviewed response	Finding
Referrer-Policy	`strict-origin-when-cross-origin`	Present
Content-Type	`text/html`	Present

Verification Notes

The browser-based verification confirmed that the redirect destination `about.gitlab.com` returned security-related HTTP response headers.

The presence of a security header does not by itself confirm that the configuration is optimal. The CSP configuration was therefore reviewed alongside the OWASP ZAP passive-scan findings documented in Section 7.

The assessment was limited to non-intrusive inspection of publicly accessible responses. No attempts were made to bypass, modify, or exploit the observed security controls.

9. Risk Summary

Two security configuration weaknesses were identified during the read-only assessment.

Finding	Risk	Confidence	Source
CSP: Failure to Define Directive with No Fallback	Medium	High	OWASP ZAP Passive Scanner
Missing Anti-clickjacking Header	Medium	Medium	OWASP ZAP Passive Scanner

Overall Risk Assessment

The assessment identified configuration-level weaknesses related to Content Security Policy and anti-clickjacking protection.

These findings may reduce the effectiveness of browser-based security controls. However, the assessment was strictly read-only and no exploitation or intrusive testing was performed. Therefore, the findings should not be interpreted as confirmation of an exploitable vulnerability.

The observed redirect from `https://gitlab.com/` to `https://about.gitlab.com/` was also taken into account when attributing the findings. Security observations associated with the redirect destination have been documented separately to avoid incorrectly attributing them to the original endpoint.

Risk Priority

1. **CSP: Failure to Define Directive with No Fallback — Medium**
    - Review and explicitly define applicable CSP directives.
    - Verify the resulting policy does not unnecessarily weaken browser security controls.
2. **Missing Anti-clickjacking Header — Medium**
    - Implement an appropriate `X-Frame-Options` policy or CSP `frame-ancestors` directive.
    - Verify that legitimate framing requirements are not affected.

10. Remediation Recommendations

The following recommendations are provided based on the security configuration observations identified during the read-only assessment.

10.1 Content Security Policy

- Review the existing Content-Security-Policy configuration.
- Explicitly define CSP directives that do not fall back to `default-src`, including `form-action`, where applicable.
- Follow the principle of least privilege when defining allowed sources.
- Avoid unnecessarily broad sources or directives.
- Test the updated CSP in a controlled environment before deployment to ensure legitimate application functionality is not affected.
- Periodically review the CSP as application functionality and third-party integrations change.

10.2 Anti-clickjacking Protection

- Configure an appropriate anti-clickjacking policy for applicable pages.
- Where framing is not required, consider using:

  `X-Frame-Options: DENY`

- Where same-origin framing is required, consider:

  `X-Frame-Options: SAMEORIGIN`

- Alternatively, use the CSP `frame-ancestors` directive to explicitly specify permitted framing origins.
- Verify that the selected policy does not interfere with legitimate application functionality.

10.3 Security Header Review

- Maintain a documented security-header baseline for publicly accessible web applications.
- Regularly review HTTP response headers for configuration changes or regressions.
- Ensure security headers are consistently applied to relevant responses, including redirects and application pages where appropriate.

- Re-test security headers after infrastructure, CDN, reverse-proxy, or application configuration changes.

10.4 Validation

After remediation, perform a follow-up passive assessment and manual response-header review to verify that the identified configuration issues have been addressed.

No remediation changes were performed during this assessment because the engagement was limited to read-only, non-intrusive testing.

11. Limitations

This assessment was conducted as a read-only, non-intrusive security review. The following limitations apply:

- Testing was limited to publicly accessible web resources.
- OWASP ZAP was used in passive scanning mode; no active scanning was performed.
- No vulnerability exploitation was attempted.
- No authentication bypass or privilege escalation testing was performed.
- No brute-force or credential attacks were performed.
- No denial-of-service or stress testing was performed.
- No modification of application data was attempted.
- Third-party domains, CDN resources, and externally hosted services observed during page loading were not assessed as part of the target's security posture.
- The assessment did not include source-code review, authenticated testing, internal infrastructure testing, or server-side configuration review.
- Passive scanner findings indicate potential security configuration weaknesses and were not independently exploited to establish practical exploitability.
- The observed redirect from `gitlab.com` to `about.gitlab.com` was taken into consideration when interpreting and attributing findings.

The results therefore represent the security posture observed within the defined scope and testing limitations at the time of assessment.

12. Conclusion

A read-only vulnerability assessment was conducted against the publicly accessible GitLab web environment using Nmap, OWASP ZAP Passive Scanner, and Chrome Developer Tools.

The assessment identified two medium-risk security configuration weaknesses:

1. CSP: Failure to Define Directive with No Fallback
2. Missing Anti-clickjacking Header

The findings primarily relate to browser security-policy configuration. Recommendations have been provided to strengthen the Content Security Policy and anti-clickjacking protections.

The assessment was intentionally limited to passive and non-intrusive techniques. Consequently, the findings should be treated as configuration observations requiring appropriate review and validation rather than confirmation of exploitable vulnerabilities.

Overall, the assessment demonstrates the importance of maintaining a consistent security-header baseline and periodically reviewing publicly exposed web configurations for security-policy weaknesses.